



Cyber Security & Digital Forensics

CSE - 4207

Lecture - 09

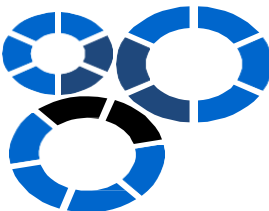
Dr. Md. Alam Hossain

Professor

Jashore University of Science and Technology

Outline

- Botnet
- DDoS using Botnet
- Botnet and C&C problem
- Advanced Persistent Threat
- Malware Obfuscation
- Unpacking



Botnet

- Bot (Zombie)

- A compromised computer under the control of an attacker
- Bot code (malware) on the computer communicates with the attacker's server and carries out malicious activities per attacker's instructions



Botnet

- Botnet

- A network of bots controlled by an attacker to perform coordinated malicious activities
- Key platform for most Internet-based attacks and frauds

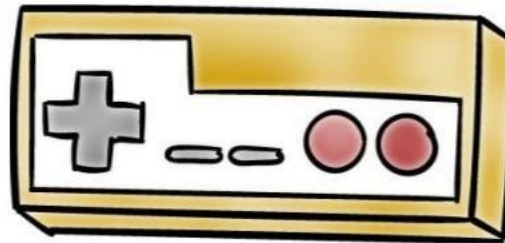
Attacks and Frauds by Botnets



- Spam
- Distributed Denial of Service (DDoS) Attacks

- Clickfraud

- Phishing & Pharming



- Cheating in online games/polls

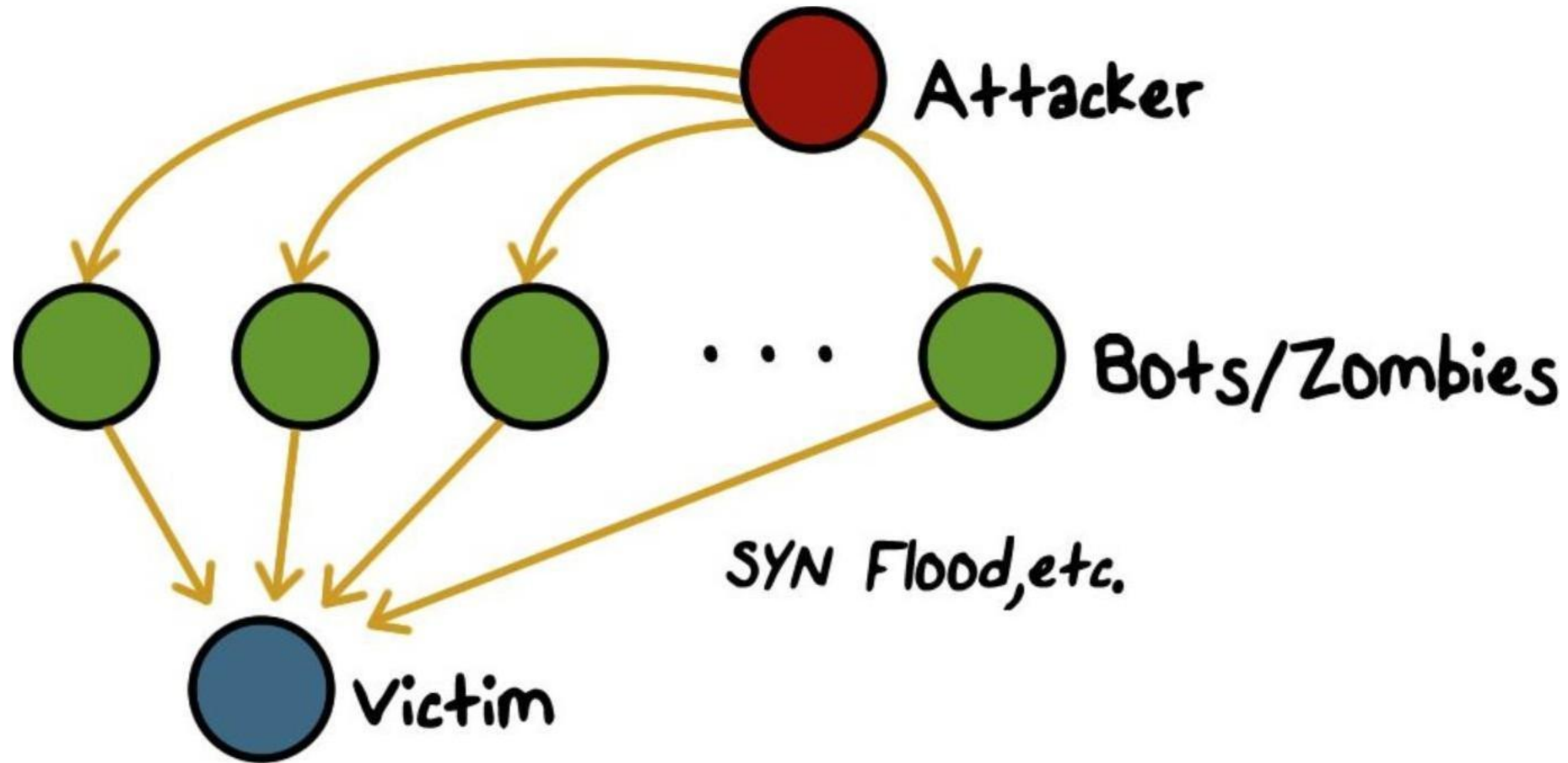
- Key Logging & Data/Identity Theft



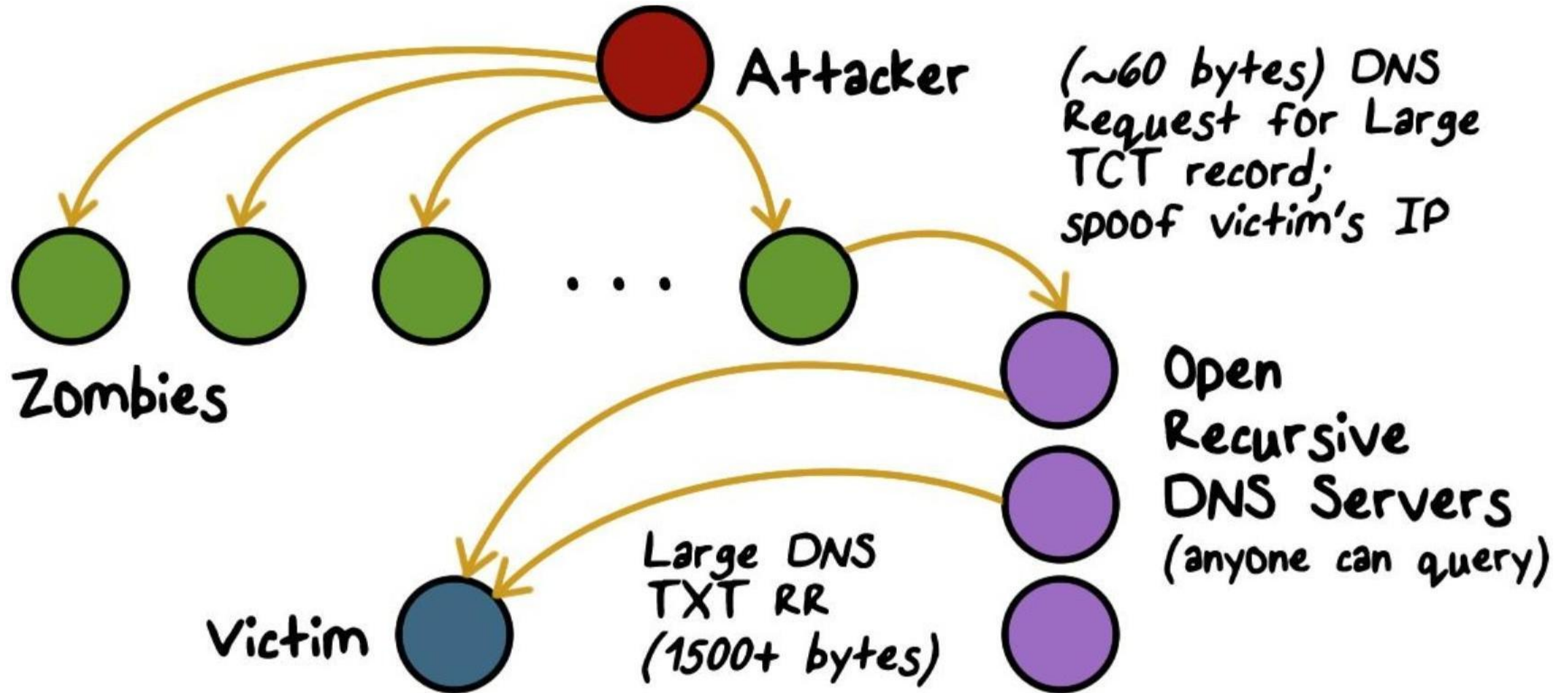
- Key/Password Cracking
...

- Anonymized Terrorist & Criminal Communication

DDos Using Botnets



Amplified Distributed Reflective Attacks



Botnet Command and Control

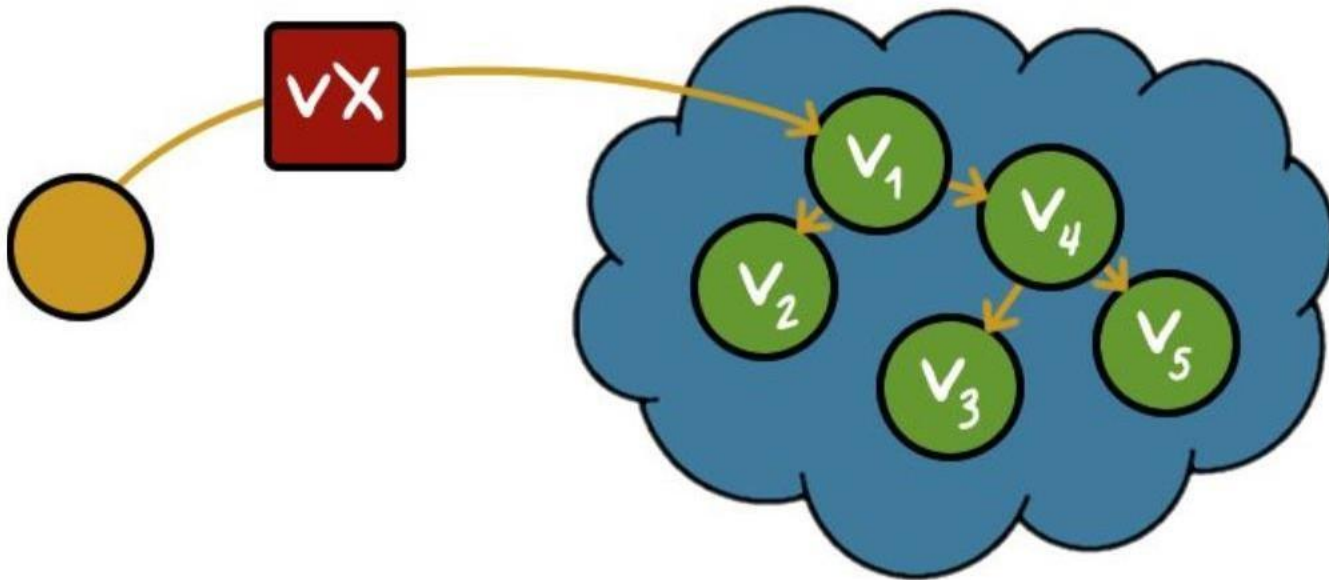
- Botnet is a network of compromised computers that the “botmaster” uses for malicious purposes



- There needs to be command & control (C&C) from the botmaster to the bots
- Example: a bot reports to the botmaster its status, is directed to a site to download a malware (botcode) update, and/or receives instructions to spam/phish/DDoS, etc.

Botnet C&C Problem

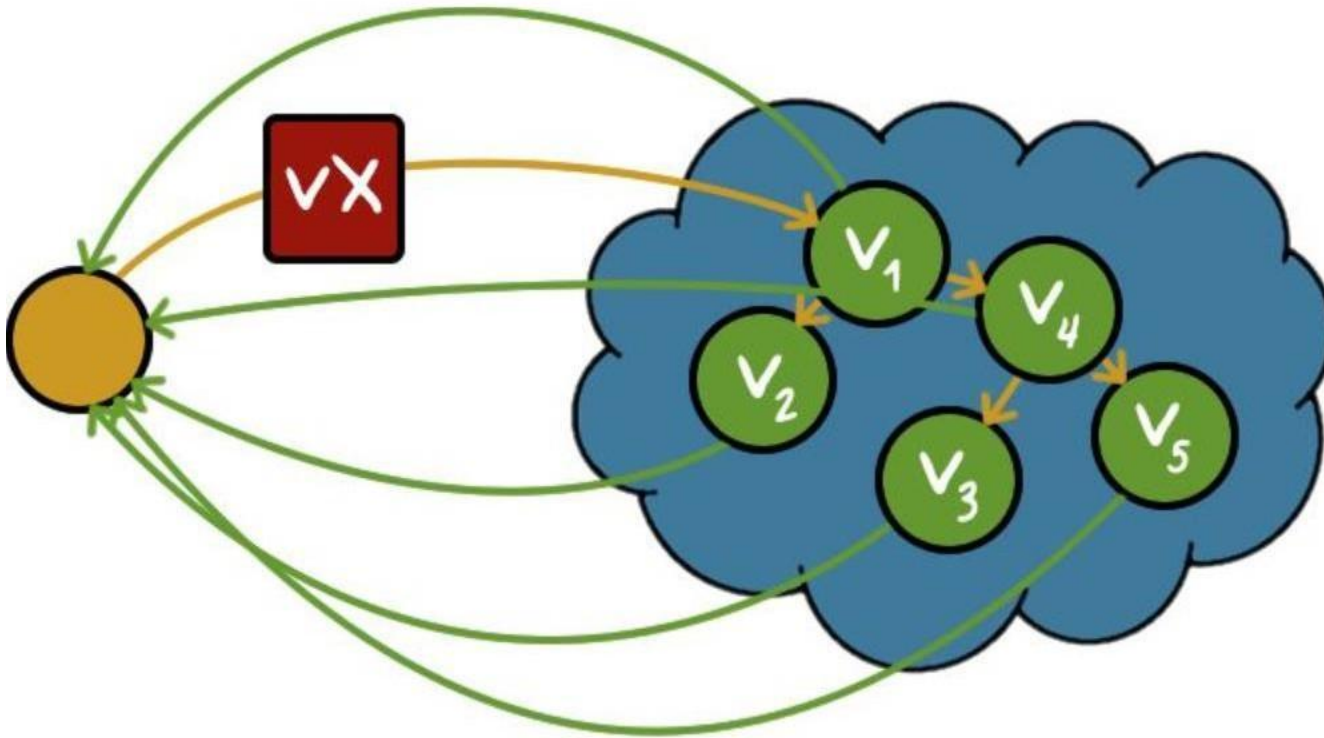
- Naively, we could have victims contact us...
 - Suppose we create malware (vx)
 - Download vx code; ddlefi compile
 - Uses email propagation/social engineering
 - We mail it...



Spreading is easy,
but what if we
want to use the
compromised computers
(victims)?

Botnet C&C– Naive Approach

- Naively, we could have victims contact us...



● Problems:

- VX must include author's address (not stealthy)
- Single rallying point (not robust)
- VX has hard-coded address (not mobile)

Botnet C&C Design

- How can bots contact their master safely?
- Simple, naïve approach:
 - Victims contact single IP, website, ping a server, etc.
 - Easily defeated (ISP intervention, blackhole routing, etc.)
 - Still used by script-kiddies, first-time malware authors



Botnet C&C Design

Design considerations:

- **Efficient and reliable**
 - Able to reach to a sizable set of bots within a time limit
- **Stealthy**
 - Hard to detect (i.e., blended with normal/regular traffic)
- **Resilient**
 - Hard to disable or block



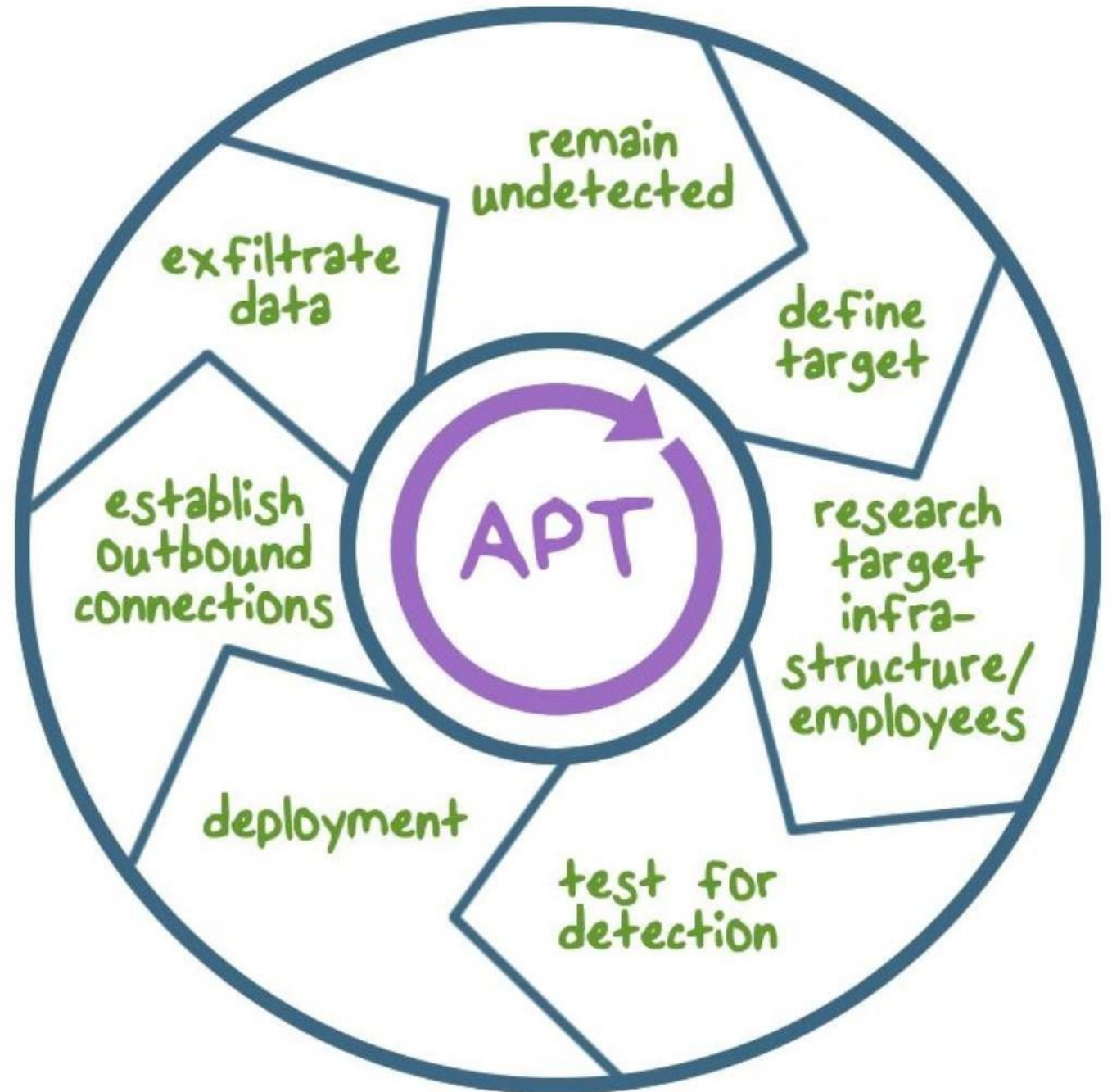
Advanced Persistent Tftreat (APT)

- **Advanced:**
 - (Special) malware
 - Special operation and operators
- **Persistent:**
 - Long-term presence, multi-step, “low-and-slow”
- **Threat:**
 - Targeted at high-value organization and information





APT Lifecycle



APT Characteristics



- **Zero-day exploit** or a specially crafted malware
- No readily available signature for its detection

APT Characteristics

Social-engineering to trick even the most sophisticated users.



Example:

- First compromise core internal network control elements such as routers and web servers to learn about the valuable targets;
- Then play man-in-the-middle (MITM) on the compromised routers/server to make social-engineering attacks very convincing, e.g., to even forge answers to challenge or inquiry by suspecting users

APT Characteristics



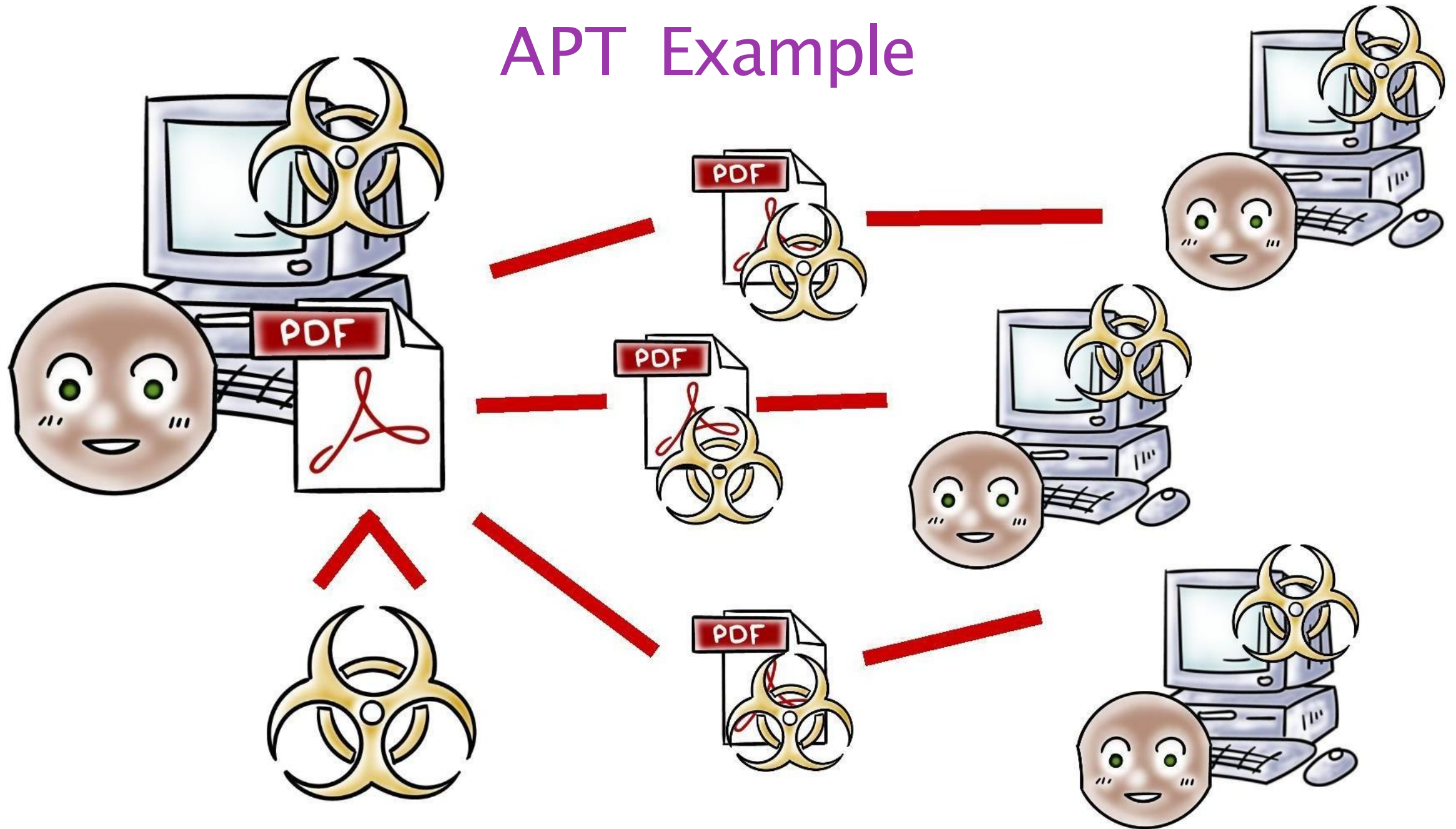
- Carry out its intended mission, such as data tampering and exfiltration, in a low-and-slow fashion to completely blend in with normal activities
- Example:
 - Acts only when the targeted user is authoring and sending a document
 - Make repeated, small incremental change to data to accomplish the eventual attack goal
 - Not detectable anomaly by existing approaches

APT Characteristics



- APT is a persistent operation that involves multiple deliberate steps over time, rather than a single attack act
- Example:
- Employ a combination of steps to move laterally through the network and target only the necessary systems and users at each attack step

APT Example





Thank You

